

Relatorio de Auditoria de Seguranca - Genexus18MCP

Revisao das cinco categorias de seguranca adaptadas a C#/.NET, Node.js, TypeScript webview e MCP local.

Data da auditoria: 17/09/2026

Base analisada: a4600828 (origin/main)

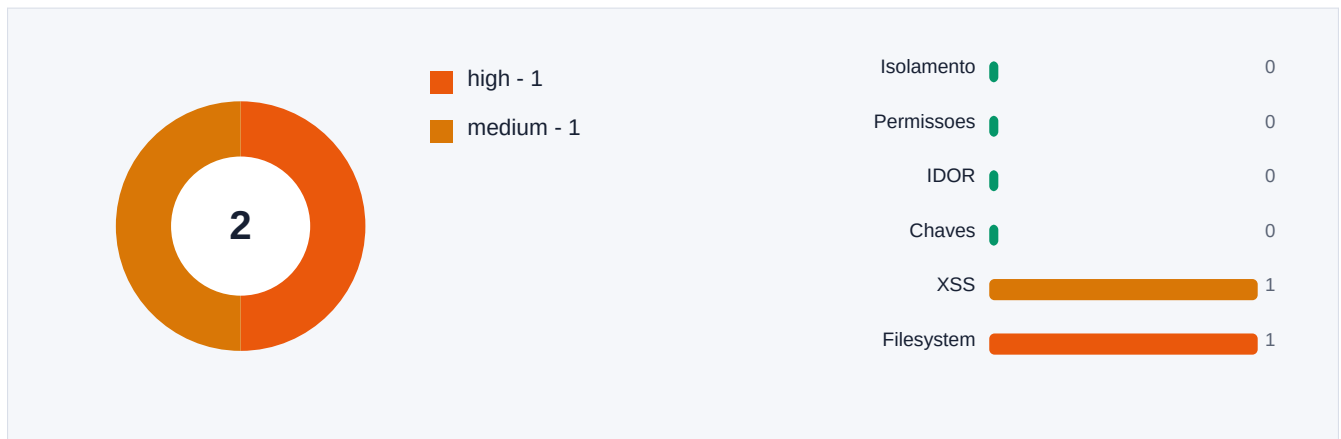
Escopo: Gateway .NET 10, Worker .NET Framework 4.8, CLI Node.js, extensao Nexus IDE, configuracoes, testes e historico Git.

Nota metodologica: isolamento e IDOR foram mapeados para leases de sessao e selecao de KB; permissao no navegador foi mapeada para a fronteira Gateway/Worker; chaves foram verificadas no codigo, configuracao, bundle e historico; XSS foi mapeado para sinks HTML dos webviews.

Resumo executivo

Foram confirmados dois achados: um de severidade alta envolvendo caminhos de filesystem e um de severidade media no titulo inicial da Indexes webview. Ambos foram corrigidos nesta branch e cobertos por validacao automatizada. Nao foram confirmados achados nas categorias de isolamento, permissao definida no navegador, IDOR ou chaves expostas.

Severidade	Quantidade	Situacao
Alta	1	Corrigida
Media	1	Corrigida
Critica / baixa	0	Nenhuma confirmada



Filesystem aparece como hardening adicional porque a lista original trata XSS como input frontend, enquanto este risco pertence a fronteira de I/O do MCP.

Stack e controles verificados

Superficie	Mapeamento e evidencia
Gateway e transporte	ASP.NET/Kestrel; origem, Host, loopback e token validados em Program.Http.cs:619-678.
Isolamento de KB	Leases vinculados a ownerScopeld, kbld, identity e contextGeneration em KbUseLeaseRegistry.cs:221-241; WorkerPool exige owner em :176-187.
Webviews	TypeScript com escapeHtml nos dados dinamicos; LayoutView usa CSP e iframe sandbox em LayoutView.ts:14-18, 53-57.
Segredos	Tokens ficam em ambiente; varredura de chave privada, AWS e JWT nao encontrou segredo real no codigo, bundle ou historico.

Cobertura por categoria

Categoria	Resultado	Evidencia de cobertura
1. Banco sem tranca	Sem achado confirmado	MCP local sem tenant remoto; a fronteira de KB e owner-bound por lease e a selecao e validada no Gateway.
2. Permissao no navegador	Sem achado confirmado	Nao ha papel administrativo confiado ao frontend; a superficie privilegiada passa pelo Gateway e guards de estado.
3. IDOR	Sem achado confirmado	Handlers percorridos por rotas e servicos; targets sao resolvidos na KB selecionada e o modelo local nao possui tenant separado do owner.
4. Chaves expostas	Sem segredo real confirmado	Tokens em ambiente; codigo, historico e bundle sem padrao confirmado de chave privada, AWS ou JWT.
5. Inputs sem tratamento (XSS)	1 media - corrigida	IndexView.ts:89 no baseline interpolava objName sem escape; a correcao esta em :90 e a suite htmlEscape cobre tag/atributo.
Hardening: filesystem	1 alta - corrigida	Export/import/blob/Object Text/baseline/profile/XPZ aceitavam Path.GetFullPath sem containment; a policy centraliza raizes.

Nao aplicavel: RLS de Supabase, middleware de tenant remoto e papeis administrativos no navegador nao fazem parte desta aplicacao local.

Pontos fortes

- HTTP recusa bind nao-loopback sem GXMCP_HTTP_TOKEN e verifica Origin/Host (Program.Http.cs:594-640, 661-678).
- Leases validam owner, KB, identity e generation antes de operacoes stateful (WorkerPool.cs:176-187; KbUseLeaseRegistry.cs:221-241).
- Structure, History e Indexes escapam dados dinamicos; Layout e Diagram usam CSP e recursos locais.
- Suites executadas: 2.824 Worker, 1.704 Gateway, 135 CLI/live-contract e 111 extensao IDE, sem falhas.

Pontos fracos corrigidos

Path.GetFullPath removia apenas ambiguidade de sintaxe, nao limitava o alvo. A nova politica comum protege leitura e escrita. A interpolacao direta no HTML inicial da Indexes webview agora usa escapeHtml. A selecao de KB nao foi alterada.

Achados detalhados

Severidade	Arquivo:linha no baseline	Descricao verificada
ALTA	src/GxMcp.Worker/Services/ObjectService.cs:3989 src/GxMcp.Worker/Services/ObjectService.cs:4161 src/GxMcp.Worker/Services/ObjectService.cs:4197 src/GxMcp.Worker/Services/ObjectTextService.cs:71 src/GxMcp.Worker/Services/ObjectTextService.cs:523 src/GxMcp.Worker/Services/ApiIntrospectService.cs:584-585 src/GxMcp.Worker/Services/ProfileService.cs:43 src/GxMcp.Worker/Services/TransferService.cs:81-82 src/GxMcp.Worker/Services/TransferService.cs:191 src/GxMcp.Worker/Services/TransferService.cs:223	The MCP caller controlled a filesystem path that was normalized but not checked against an authorized root. The tools could read local files or write exports outside the active KB.
MEDIA	src/nexus-ide/src/webviews/IndexPath.ts:89	The object name came from a workspace URI and was interpolated into the initial HTML document. A crafted name could terminate the text context and inject markup or script content.

SEC-001 - Restringir caminhos de troca de arquivos

Por que é explorável: The MCP caller controlled a filesystem path that was normalized but not checked against an authorized root. The tools could read local files or write exports outside the active KB.

Impacto: A caller able to invoke the local MCP surface could access or overwrite unrelated files within the account filesystem permissions.

Condição: The caller must reach the MCP tool and the process keeps the same local account permissions. This is not a cross-account sandbox escape.

Evidência do baseline:

```
src/GxMcp.Worker/Services/ObjectService.cs:3989 - fullPath = Path.GetFullPath(outputPath);
src/GxMcp.Worker/Services/ObjectService.cs:4161 - string fullPath = Path.GetFullPath(outputPath);
src/GxMcp.Worker/Services/ObjectService.cs:4197 - string fullPath = Path.GetFullPath(inputPath);
src/GxMcp.Worker/Services/ObjectTextService.cs:71 - try { root = Path.GetFullPath(outputPath); }
src/GxMcp.Worker/Services/ObjectTextService.cs:523 - try { full = Path.GetFullPath(inputPath); }
src/GxMcp.Worker/Services/ApiIntrospectService.cs:584-585 - if (Path.IsPathRooted(baselineArg) &&
File.Exists(baselineArg))
src/GxMcp.Worker/Services/ProfileService.cs:43 - if (!File.Exists(path))
src/GxMcp.Worker/Services/TransferService.cs:81-82 - string outputFile = args?["outputFile"]?.ToString();
src/GxMcp.Worker/Services/TransferService.cs:191 - if (!System.IO.File.Exists(file))
src/GxMcp.Worker/Services/TransferService.cs:223 - if (!System.IO.File.Exists(file))
```

Correção verificada:

```
src/GxMcp.Worker/Utils/IUserFilePathPolicy.cs:1-13 - small port for file-path consumers
src/GxMcp.Worker/Utils/UserFilePathPolicy.cs:29-91 - normalization, root resolution, and containment diagnostics
src/GxMcp.Worker/Services/CommandDispatcher.cs:186 - composition root creates one shared policy
src/GxMcp.Worker/Services/ObjectService.cs:3998;4169;4215 - policy before blob, part export, and part import I/O
src/GxMcp.Worker/Services/ObjectTextService.cs:82;535 - policy on batch output and input
src/GxMcp.Worker/Services/ApiIntrospectService.cs:596 - baseline restricted and JSON extension checked
src/GxMcp.Worker/Services/ProfileService.cs:58 - profile restricted before XML read
src/GxMcp.Worker/Services/TransferService.cs:96;207;243 - XPZ export, inspect, and import restricted
```

SEC-002 - Escapar nome de objeto no título da Indexes webview

Por que é explorável: The object name came from a workspace URI and was interpolated into the initial HTML document. A crafted name could terminate the text context and inject markup or script content.

Impacto: Opening the Indexes view for a maliciously named object could execute attacker-controlled webview markup in the extension context.

Condição: The attacker must control or cause the object name to be present in the workspace URI and the user must open the Indexes view.

Evidência do baseline:

```
src/nexus-ide/src/webviews/IndexPath.ts:89 - toolbar interpolated objName directly into HTML
```

Correção verificada:

```
src/nexus-ide/src/webviews/IndexPath.ts:4 - import escapeHtml from the shared HTML helper
src/nexus-ide/src/webviews/IndexPath.ts:90 - Indexes for escaped objName
```

src/nexus-ide/src/test/suite/htmlEscape.test.ts:1-38 - tag and attribute breakout regression coverage

Recomendacoes priorizadas

P1 - manter IUserFilePathPolicy como unica porta de entrada para arquivos fornecidos por MCP, com UserFilePathPolicy criada no composition root, e adicionar um teste para cada novo parametro de path.

P2 - executar o gate de PR deste diretorio em copia limpa baseada no origin/main, com SDK explicitamente selecionado.

P3 - repetir a varredura de segredos em codigo, historico e bundle; manter tokens apenas em ambiente.

P4 - acompanhar os sete avisos de npm audit somente na arvore de desenvolvimento do IDE; npm audit --omit=dev nao encontrou vulnerabilidades de runtime.

ISSUES PARA O GITHUB

Blocos completos, sanitizados e prontos para copiar. Os achados foram corrigidos nesta branch; mantenha-os como registro ou rastreie a correcao no repositorio upstream.

```

--- ISSUE SEC-001 ---
# [Seguranca] Restringir caminhos de troca de arquivos

Labels sugeridas: security, severity:alta

## Descricao
The MCP caller controlled a filesystem path that was normalized but not checked against an authorized root. The tools
could read local files or write exports outside the active KB.

## Evidencia
- src/GxMcp.Worker/Services/ObjectService.cs:3989 - fullPath = Path.GetFullPath(outputPath);
- src/GxMcp.Worker/Services/ObjectService.cs:4161 - string fullPath = Path.GetFullPath(outputPath);
- src/GxMcp.Worker/Services/ObjectService.cs:4197 - string fullPath = Path.GetFullPath(inputPath);
- src/GxMcp.Worker/Services/ObjectTextService.cs:71 - try { root = Path.GetFullPath(outputPath); }
- src/GxMcp.Worker/Services/ObjectTextService.cs:523 - try { full = Path.GetFullPath(inputPath); }
- src/GxMcp.Worker/Services/ApiIntrospectService.cs:584-585 - if (Path.IsPathRooted(baselineArg) &&
File.Exists(baselineArg))
- src/GxMcp.Worker/Services/ProfileService.cs:43 - if (!File.Exists(path))
- src/GxMcp.Worker/Services/TransferService.cs:81-82 - string outputFile = args?["outputFile"]?.ToString();
- src/GxMcp.Worker/Services/TransferService.cs:191 - if (!System.IO.File.Exists(file))
- src/GxMcp.Worker/Services/TransferService.cs:223 - if (!System.IO.File.Exists(file))

## Impacto
A caller able to invoke the local MCP surface could access or overwrite unrelated files within the account filesystem
permissions.

## Condicao de explorabilidade
The caller must reach the MCP tool and the process keeps the same local account permissions. This is not a cross-account
sandbox escape.

## Sugestao de correcao
Centralize normalization and containment. Anchor relative paths at the active KB; allow the configured Genexus
installation and an explicit GXMCP_EXTERNAL_IO_ROOT staging directory; reject traversal and report effective roots.

## Critérios de aceite
- [ ] Relative, quoted, spaced, and mixed-slash Windows paths resolve from the active KB.
- [ ] Absolute paths and traversal outside roots return PathOutsideAllowedRoots before I/O.
- [ ] Blob, part, Object Text, baseline, profile, and XPZ paths use the same policy.
- [ ] Diagnostics report target and roots without secrets or customer KB values.
--- FIM ISSUE SEC-001 ---

--- ISSUE SEC-002 ---
# [Seguranca] Escapar nome de objeto no titulo da Indexes webview

Labels sugeridas: security, severity:media

## Descricao
The object name came from a workspace URI and was interpolated into the initial HTML document. A crafted name could
terminate the text context and inject markup or script content.

## Evidencia
- src/nexus-ide/src/webviews/IndexView.ts:89 - toolbar interpolated objName directly into HTML

## Impacto
Opening the Indexes view for a maliciously named object could execute attacker-controlled webview markup in the extension
context.

## Condicao de explorabilidade
The attacker must control or cause the object name to be present in the workspace URI and the user must open the Indexes
view.

## Sugestao de correcao
Escape untrusted text before HTML interpolation and keep dynamic table cells on the existing escapeHtml path.

## Critérios de aceite
- [ ] The title is escaped before assignment to webview HTML.
- [ ] Existing index names, attributes, and error messages remain escaped.
- [ ] The webview and HTML escape regression tests pass.
--- FIM ISSUE SEC-002 ---

```

Reprodutibilidade e limites

Auditoria feita na revisao a4600828 (origin/main). Nenhuma KB real foi aberta, alterada, gerada ou publicada durante a leitura; testes usam dados temporarios e anonimizados. O Worker foi compilado contra GeneXus 18 U16 local. Sem SDK configurado, o preflight retorna GXMCP_SDK_PATH_MISSING.